

Penetration Test Technical Report

For Artemis, Incorporated (“Artemis”)

Version 1.0

March 11th, 2023

Written by: Holly Metzger

Document Properties

Title	Penetration Test Technical Report
Version	1.0
Author	Holly Metzger
Penetration Testers	Holly Metzger
Reviewed by	Yushen Wei
Approved by	CISO

Version Control/History

Version	Date	Author	Description
1.0	03/11/23	Holly Metzger	First Draft
2.0	03/14/23	Holly Metzger	Final Draft

Table of Contents

1. Prefix
2. Executive Summary
 - a. Synopsis
 - b. Findings Overview
 - c. Recommendations
3. Factors
 - a. Scope of Work
 - b. Assessment Objectives
 - c. Assumptions
 - d. Proposed Timeline
4. Methodology
 - a. Phases of testing
 - i. Intelligence Gathering
 - ii. Enumeration
 - iii. Vulnerability Scanning
 - iv. Threat Assessment
 - b. Vulnerability Ranking Methodology
5. Findings Report
 - a. Unpatched RDP is exposed to the internet
 - b. Web application is vulnerable to SQL Injection
 - c. Default password on Cisco admin portal
 - d. Apache web server vulnerable to CVE-2019-0211
 - e. Web server is exposing sensitive data
 - f. Web application has broken access control
 - g. Oracle WebLogic Server vulnerable to CVE-2020-14882
 - h. Misconfigured cloud storage (AWS security group misconfiguration, lack of
 - i. access restrictions)
 - j. Microsoft Exchange Server vulnerable to CVE-2021-2685
6. Appendix

Executive Summary

Synopsis

A total of nine vulnerabilities were found within the organization. They are sorted into four categories: network configuration, host configuration, cloud, and web application. Of these vulnerabilities, two were medium severity, three were high, three were critical, and one was unknown. The average CVSS score across all vulnerabilities was 7.5.

Findings Overview

Vulnerability	Category	Severity
Unpatched RDP is exposed to the internet	Network Configuration	4.2
Web application is vulnerable to SQL Injection	Web Application	9.1
Default password on Cisco admin portal	Host Configuration	7.2
Apache web server vulnerable to CVE-2019-0211	Web Application	8.8
Web server is exposing sensitive data	Web Application	Unknown
Web application has broken access control	Web Application	5.3
Oracle WebLogic Server vulnerable to CVE-2020-14882	Host Configuration	9.8
Misconfigured cloud storage (AWS security group misconfiguration, lack of access restrictions)	Cloud	7.1
Microsoft Exchange Server vulnerable to CVE-2021-26855	Host Configuration	9.1

Recommendations

As the web application category contained the most vulnerabilities (including those whose severity could not be determined), as well as highly sensitive intellectual property of the organization, recommendation is to begin remediation efforts with the web applications. Additionally, Artemis may want to consider storing company IP on an alternate system from the

web server, as web servers by their nature of being open to the internet are more susceptible to attack.

Many of the vulnerabilities can be mitigated by applying security patches. Recommendation is to review patch versions of all systems starting with those containing the most sensitive data, and apply the latest patches to all systems.

Following are three projects that would help to mature the security of Artemis. First is to conduct inventory of all physical network assets. This includes type and model of device, as well as the OS and version. From this inventory a network diagram can be created. This will give senior management more visibility into the workings of the technical infrastructure, and help network administrators and other IT staff to conduct their work more thoroughly and efficiently. Second is to conduct data classification. This will give insight into how Artemis uses its data, and make the data easier to parse by humans and AI, thus making it easier to protect. Third is to conduct staff training on company policy regarding usage of the cloud, and inventory management and patching. These projects are aligned with the initial concerns Artemis brought and account for the critical findings discovered in the assessment.

Assessment Factors

Scope of Work

The penetration test will attempt to discover vulnerabilities in the following systems:

- Internal network
- Cloud infrastructure
- Web applications (Apollo and PARS)

The final product will be two deliverables: an executive summary containing high-level results and focusing on business impacts, and a detailed technical report containing information on each vulnerability discovered along with mitigation recommendations.

Assessment Objectives

The objectives of this pentest are as follows:

- To assess the state of cybersecurity controls in the organization
- To provide a practical demonstration of those controls' effectiveness
- To provide an estimate of the organization's susceptibility to exploitation and/or data breaches

Assumptions

The organization is widely spread over the globe and uses a mixture of equipment and service providers. Additionally, their network diagram is out of date. These factors indicate that visibility into the workings of the IT/Security infrastructure is low.

Artemis employs engineers who develop patents. They have a high concentration of confidential knowledge. They may be at a higher risk of attack from competitors seeking to steal their intellectual property.

Timeline

Stage	Start Date	End Date	Duration	Comments
Pre-engagement interactions	03/01/23	03/01/23	1 day	
Reconnaissance	03/02/23	03/03/23	2 days	
Enumeration	03/04/23	03/06/23	3 days	
Vulnerability Scanning	03/07/23	03/09/23	3 days	
Threat Assessment	03/10/23	03/14/23	5 days	
Report Delivery	03/14/23	03/14/23	1 day	

Methodology

Stages of Testing

I. Intelligence Gathering

Intelligence Gathering is performing reconnaissance against a target to gather as much information as possible to be utilized when penetrating the target during the vulnerability assessment and exploitation phases. The more information you are able to gather during this phase, the more vectors of attack you may be able to use in the future.

Open source intelligence (OSINT) is a form of intelligence collection management that involves finding, selecting, and acquiring information from publicly available sources and analyzing it to produce actionable intelligence.

We will conduct level 2 intelligence gathering (IG), as it is an appropriate level to assess the security of the organization and bring it up to an acceptable level. The following categories will be considered:

- Business Relationships
- Infrastructure Assets
- Employee Data

II. Enumeration

This phase of testing consists of host and service discovery. This process will give us a list of “hosts,” or machines currently in use, and tell us what OS and programs they are running. This will tell us which machines are potentially vulnerable, and will guide us through the rest of the testing. The following tools will be used:

- Nmap
- Host
- Domain Information Groper (DIG)
- NetCraft

III. Vulnerability Scanning

Vulnerability scanning is the process of running automated tools to search the target system or network for indicators of known vulnerabilities. Each tool will give insight into how an attacker may compromise a system. The following tools will be used for vulnerability scanning:

- Burpsuite
- Nessus
- OpenVAS
- Sqlmap
- SecretScanner
- RDPScan

IV. Threat Assessment

This phase consists of assessing the output of a vulnerability scan to weed out false positives, gain a deeper understanding of each vulnerability’s risk to the organization, and rank them based on criticality. Each vulnerability found will be given a value of its description, OS/Versions affected, Risk to organization, remediation options, and CVSS score.

Vulnerability Ranking Methodology

In ranking each vulnerability found, the Common Vulnerability Scoring System version 3.1 (CVSS) will be used. CVSS consists of three metric groups: Base, Temporal, and Environmental. The Base group represents the intrinsic qualities of a vulnerability that are constant over time and across user environments, the Temporal group reflects the characteristics of a vulnerability that change over time, and the Environmental group represents the characteristics of a vulnerability that are unique to a user's environment. The Base metrics produce a score ranging from 0 to 10, which can then be modified by scoring the Temporal and Environmental metrics. A CVSS score is also represented as a vector string, a compressed textual representation of the values used to derive the score.

The scores associated to each vulnerability are ranked as follows:

0 - 3.9	Low
4.0 - 6.9	Medium
7.0 - 8.9	High
9.0 - 10.0	Critical

Findings Report

Title	Unpatched RDP is exposed to the internet
CVSS	4.2 (Medium)
Category	Network Configuration
Description	Remote Desktop Protocol is used to allow users to access their desktop from remote systems. As vulnerabilities are found within it, they are patched by Microsoft. If our version does not have the latest patch, that means it can be exploited. If it is exposed to the internet that means it can be exploited over the internet, meaning an attacker could exploit this vulnerability from anywhere.
Risk	An attacker with a user's credentials could access that user's desktop from anywhere. Depending on the privileges of the compromised account, they could exfiltrate data, install malware, or attempt privilege escalation.

Mitigation	- Apply the most recent patch. - Set firewall rules to only allow access during business hours and from applicable geographic locations. - Whitelist pre-approved IP addresses and deny connections from unknown sources.
-------------------	---

Title	Web application is vulnerable to SQL Injection
CVSS	9.1 (Critical)
Category	Web Application
Description	A very common vulnerability which allows an attacker to enter SQL code into an input field on the website, which will result in unintended information being accessed. They may use this to obtain sensitive data stored on the web server such as user credentials or trade secrets, or back end information about the database and filesystem that will aid in other attacks.
Risk	An attacker may gain unauthorized access to data, or delete or alter the data. There is a lot of secret information stored on the web apps that could cause a loss in future profit. Additionally, if employee and customer data is lost, the organization may face regulatory consequences.
Mitigation	- Conduct code review of the web application to ensure input validation and parameterization are in place. - Implement a WAF to block malicious signatures and IP addresses.

Title	Default password on Cisco admin portal
CVSS	7.2 (High)
Category	Host Configuration
Description	Devices such as routers and firewalls will come with a default username and password to administer them. These should be changed before deploying them into production, as they are easily looked up in device manuals online. Any default password should be assumed to be known to all attackers.

Risk	An attacker could change any configuration setting on the device, give themselves a backdoor, or use it to gain a shell on connected equipment.
Mitigation	- Change the password. - Review logging policy and configure alerts for suspicious login attempts.

Title	Apache web server vulnerable to CVE-2019-0211
CVSS	8.8 (High)
Category	Web Application
Description	A flaw was found in Apache where code executing in a less-privileged child process or thread could execute arbitrary code with the privilege of the parent process (usually root). An attacker having access to run arbitrary scripts on the web server (PHP, CGI etc) could use this flaw to run code on the web server with root privileges.
Risk	An attacker could conduct privilege escalation or lateral movement through the network. They could execute malware with a privileged shell. They could use this to install malware such as keyloggers, worms, ransomware, or a backdoor to access the network at any time.
Mitigation	- Update the Apache servers to version 2.4.39 or newer. - Place the web server in a DMZ to block access to the internal network should an attacker gain control of the web server.

Title	Web server is exposing sensitive data
CVSS	10.0 (Unknown)
Category	Web Application
Description	The web server hosts a lot of sensitive data. Some factors that may lead to it being exposed are lack of data classification, vulnerabilities on the web application, lack of encryption, and weak identity/access management policies.
Risk	Website may be exposing critical information, which may lead to damaged reputation, loss of profit, and regulatory consequences.
Mitigation	- Remediate vulnerabilities in code of web application

- Conduct data classification of data stored in web server to determine its sensitivity
- Segment the web server from the internal network
- Update IAM policies.

Title Web application has broken access control

CVSS 5.3 (Medium)

Category Web Application

Description Access control determines which users and devices can access the web application. These rules are configured through group policy on the Identity/Access Management system. It is important to use appropriate access control according to least privilege, so users can perform effectively while minimizing the level of potential damage if their account was to be compromised.

Risk Malicious users may access data they should not have access to. An attacker may use a compromised account to exfiltrate data or modify the data or web application itself.

Mitigation - Review group policy and access control rules and set them according to least privilege.
- Implement logging policy and configure alerts upon suspicious activity such as repeated failed login attempts, unusual time/location of access, and unknown IP address.

Title Oracle WebLogic Server vulnerable to CVE-2020-14882

CVSS 9.8 (Critical)

Category Host Configuration

Description Vulnerability in the Oracle WebLogic Server product of Oracle Fusion Middleware (component: Console). Easily exploitable vulnerability allows unauthenticated attacker to compromise Oracle WebLogic Server with only one HTTP GET request. Successful attacks of this vulnerability can result in takeover of Oracle WebLogic Server via Remote Code Execution.

Risk	This vulnerability can give an attacker complete control over the compromised system, allowing them to execute all sorts of malware including ransomware, spyware, Denial of Service, etc
Mitigation	- Apply firewall rules to block all but the most necessary access to the server admin page. - Review application logs for HTTP requests that include the double-encoded path traversal %252E%252E%252F and the admin portal console.portal in the request URI. - Monitor for any suspicious processes created by the application, such as cmd.exe or /bin/sh
Title	Misconfigured cloud storage (AWS security group misconfiguration, lack of access restrictions)
CVSS	7.1 (High)
Category	Cloud
Description	In AWS, a security group controls the traffic that is allowed to reach and leave the resources that it is associated with, acting like a firewall ACL. For example, after you associate a security group with an EC2 instance, it controls the inbound and outbound traffic for the instance.
Risk	Poorly configured security groups allow for unauthorized access of the network. This is compounded by poor understanding of network diagram. An attacker may be able to access the internal network through the DMZ if proper rules are not configured. This could lead to data exfiltration, denial of service, or other attacks.
Mitigation	- Authorize only specific IAM principals to create and modify security groups. - Create the minimum number of security groups needed. Use each security group to manage access to resources that have similar functions and security requirements. - Create a whitelist of IPs to access configuration settings through SSH and RDP - Do not open large port ranges. Ensure that access through each port is restricted to the sources or destinations that require it. - Create network ACLs with rules similar to the security groups, to add an additional layer of security to the VPC.

Title	Microsoft Exchange Server vulnerable to CVE-2021-26855
CVSS	9.1 (Critical)
Category	Host Configuration
Description	This vulnerability is part of a chain of attacks to target Microsoft Exchange Server, with the end goal being to install a web shell which serves as a backdoor, allowing for future attacks. This vulnerability paves the way for further attacks by using server-side-request-forgery (SSRF) to establish HTTPS connections and authenticate themselves to the Exchange server.
Risk	An attacker may gain access to employee emails, calendar information, or any data stored on the server. They could use this information for crafting spear phishing emails, or as reconnaissance for a more in depth attack.
Mitigation	- Block internet access to port 443 (HTTPS) - Apply the security patch from Microsoft